Travaux Pratiques 4

Sécurisation avancée d'un serveur WEB

WAF, Fail2Ban, En-têtes HTTP & Monitoring

Partie 1 : Mise en place d'un WAF avec ModSecurity

ModSecurity est un pare-feu applicatif web (WAF) open source qui protège contre les attaques web courantes comme les injections SQL, le cross-site scripting (XSS), et bien d'autres.

Installation de ModSecurity

Installez ModSecurity et le module Apache :

```
$ sudo apt update
$ sudo apt install libapache2-mod-security2
```

Activez le module :

```
$ sudo a2enmod security2
$ sudo systemctl restart apache2
```

Configuration de base

Copiez le fichier de configuration recommandé :

```
$ sudo cp /etc/modsecurity/modsecurity.conf-recommended
/etc/modsecurity/modsecurity.conf
```

Éditez le fichier pour activer ModSecurity :

```
$ sudo nano /etc/modsecurity/modsecurity.conf
```

Modifiez la ligne suivante :

```
SecRuleEngine DetectionOnly
# Remplacez par :
SecRuleEngine On
```

Installation des règles OWASP CRS

Le Core Rule Set (CRS) de l'OWASP fournit un ensemble de règles de détection d'attaques :

```
$ sudo apt install modsecurity-crs
# Ou téléchargez la dernière version :
$ cd /etc/modsecurity
$ sudo git clone https://github.com/coreruleset/coreruleset.git
 $ sudo mv coreruleset/crs-setup.conf.example crs-setup.conf
$ sudo mv coreruleset/rules/ .
```

Configuration Apache pour ModSecurity

Éditez le fichier de configuration :

```
$ sudo nano /etc/apache2/mods-enabled/security2.conf
```

Ajoutez ou vérifiez les lignes suivantes :

```
<IfModule security2_module>
   SecDataDir /var/cache/modsecurity
   IncludeOptional /etc/modsecurity/*.conf
   IncludeOptional /etc/modsecurity/rules/*.conf
</IfModule>
```

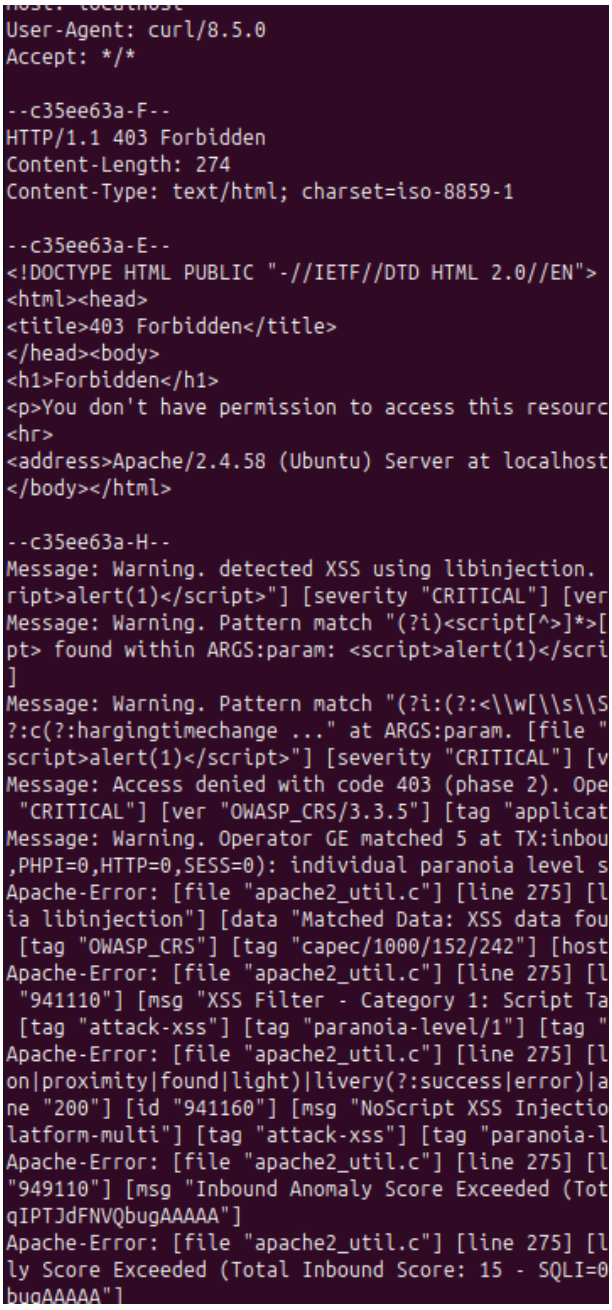
Redémarrez Apache :

```
$ sudo systemctl restart apache2
```

Test de ModSecurity

Testez avec une requête malveillante simulée :

```
$ curl 'http://localhost/?param=<script>alert(1)</script>'
# Vérifiez les logs sur un autre onglet. Lancez la commande ci-dessous avant celle-ci-
dessus:
$ sudo tail -f /var/log/apache2/modsec_audit.log
```



Partie 2 : Protection contre les attaques par force brute avec Fail2Ban

Fail2Ban analyse les fichiers de logs et bannit automatiquement les adresses IP qui présentent des comportements malveillants.

Installation de Fail2Ban

```
$ sudo apt install fail2ban
```

Configuration pour Apache

Créez un fichier de configuration local :

```
$ sudo nano /etc/fail2ban/jail.local
```

Ajoutez le contenu suivant :

```
[DEFAULT]
bantime = 3600
findtime = 600
maxretry = 5
ignoreip = 127.0.0.1/8 ::1

[apache-auth]
enabled = true
port = http,https
filter = apache-auth
logpath = /var/log/apache2/*error.log
maxretry = 3

[apache-badbots]
enabled = true
port = http,https
filter = apache-badbots
logpath = /var/log/apache2/*access.log
maxretry = 2

[apache-noscript]
enabled = true
port = http,https
filter = apache-noscript
logpath = /var/log/apache2/*error.log

[apache-overflows]
enabled = true
port = http,https
filter = apache-overflows
logpath = /var/log/apache2/*error.log
maxretry = 2

[apache-modsecurity]
enabled = true
port = http,https
filter = apache-modsecurity
logpath = /var/log/apache2/modsec_audit.log
maxretry = 2
```

Création du filtre ModSecurity

Créez le filtre pour ModSecurity :

```
$ sudo nano /etc/fail2ban/filter.d/apache-modsecurity.conf
```

Contenu du fichier :

```
 [Definition]
failregex = \[.*\] \[client <HOST>\] ModSecurity:.*
ignoreregex =
```

Démarrage et vérification

```
$ sudo systemctl enable fail2ban
```

```
$ sudo systemctl restart fail2ban
# Vérifier le statut :
$ sudo fail2ban-client status
# Voir les IP bannies pour un jail spécifique :
$ sudo fail2ban-client status apache-auth
# Débannir une IP :
$ sudo fail2ban-client set apache-auth unbanip 192.168.1.100
```

```
elisee@elisee-VMware-Virtual-Platform:~$ sudo fail2ban-client status
Status
|- Number of jail:      6
`- Jail list:   apache-auth, apache-badbots, apache-modsecurity, apache-noscript, apache-overflows, ss
hd
elisee@elisee-VMware-Virtual-Platform:~$ sudo fail2ban-client status apache-auth
Status for the jail: apache-auth
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     0
|  `- Journal matches:
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `- Banned IP list:
elisee@elisee-VMware-Virtual-Platform:~$ sudo fail2ban-client set apache-auth unbanip 192.168.1.100
0
```

Paramètres importants

Paramètre	Description
bantime	Durée du bannissement en secondes (3600 = 1 heure)
findtime	Fenêtre de temps pour compter les tentatives
maxretry	Nombre de tentatives avant bannissement
ignoreip	IPs à ne jamais bannir (localhost, admin)

Partie 3 : Configuration des en-têtes de sécurité HTTP

Les en-têtes de sécurité HTTP permettent de protéger les utilisateurs contre diverses attaques côté client (XSS, clickjacking, etc.).

Activation du module headers

```
$ sudo a2enmod headers
$ sudo systemctl restart apache2
```

Configuration des en-têtes

Éditez le fichier de configuration de sécurité Apache :

```
$ sudo nano /etc/apache2/conf-available/security.conf
```

Ajoutez les en-têtes suivants :

```
# Protection contre le clickjacking
Header always set X-Frame-Options "SAMEORIGIN"

# Protection XSS (navigateurs anciens)
Header always set X-XSS-Protection "1; mode=block"
```

```
# Empêcher le MIME-sniffing
Header always set X-Content-Type-Options "nosniff"

# Politique de référent
Header always set Referrer-Policy "strict-origin-when-cross-origin"

# Content Security Policy (CSP)
Header always set Content-Security-Policy "default-src 'self'; \
script-src 'self'; style-src 'self' 'unsafe-inline'; \
img-src 'self' data:; font-src 'self'; \
frame-ancestors 'self'; form-action 'self'"

# Permissions Policy (remplace Feature-Policy)
Header always set Permissions-Policy "geolocation=(), microphone=(), camera=()"

# Strict Transport Security (HSTS) - uniquement si HTTPS Header always set Strict-
Transport-Security \
"max-age=31536000; includeSubDomains; preload"
```

Explication des en-têtes

En-tête	Protection
X-Frame-Options	Empêche l'inclusion dans des iframes (anti-clickjacking)
X-XSS-Protection	Active le filtre XSS des navigateurs (legacy)
X-Content-Type-Options	Empêche la détection automatique du type MIME
Referrer-Policy	Contrôle les informations envoyées dans le header Referer
Content-Security-Policy	Définit les sources autorisées pour scripts, styles, etc.
Permissions-Policy	Contrôle l'accès aux APIs du navigateur (caméra, micro, etc.)
HSTS	Force l'utilisation de HTTPS pendant une durée définie

Application et test

```
$ sudo systemctl restart apache2

# Testez les en-têtes avec curl :
$ curl -I https://localhost

# Ou utilisez le site securityheaders.com pour une analyse complete
```

```
elisee@elisee-VMware-Virtual-Platform:~$ curl -I https://securityheaders.com
HTTP/2 403
date: Tue, 09 Dec 2025 15:43:54 GMT
content-type: text/html; charset=UTF-8
content-length: 6984
accept-ch: Sec-CH-UA-Bitness, Sec-CH-UA-Arch, Sec-CH-UA-Full-Version, Sec-CH-UA-Mobile, Sec-CH-UA-Model, Sec-CH-UA-Platform-Version, Sec-CH-UA-Full-Version-List, Sec-CH-UA-Platform, Sec-CH-UA, UA-Bitness, UA-Arch, UA-Full-Version, UA-Mobile, UA-Model, UA-Platform-Version, UA-Platform, UA
cf-mitigated: challenge
critical-ch: Sec-CH-UA-Bitness, Sec-CH-UA-Arch, Sec-CH-UA-Full-Version, Sec-CH-UA-Mobile, Sec-CH-UA-Model, Sec-CH-UA-Platform-Version, Sec-CH-UA-Full-Version-List, Sec-CH-UA-Platform, Sec-CH-UA, UA-Bitness, UA-Arch, UA-Full-Version, UA-Mobile, UA-Model, UA-Platform-Version, UA-Platform, UA
cross-origin-embedder-policy: require-corp
cross-origin-opener-policy: same-origin
cross-origin-resource-policy: same-origin
origin-agent-cluster: ?1
permissions-policy: accelerometer=(),browsing-topics=(),camera=(),clipboard-read=(),clipboard-write=(),geolocation=(),gyroscope=(),hid=(),interest-cohort=(),magnetometer=(),microphone=(),payment=(),publickey-credentials-get=(),screen-wake-lock=(),serial=(),sync-xhr=(),usb=()
referrer-policy: same-origin
server-timing: chlray;desc="9ab59ef00f04d0a3"
x-content-type-options: nosniff
x-frame-options: SAMEORIGIN
cache-control: private, max-age=0, no-store, no-cache, must-revalidate, post-check=0, pre-check=0
expires: Thu, 01 Jan 1970 00:00:01 GMT
server: cloudflare
cf-ray: 9ab59ef00f04d0a3-CDG
```

Partie 4 : Monitoring et analyse des logs avec GoAccess

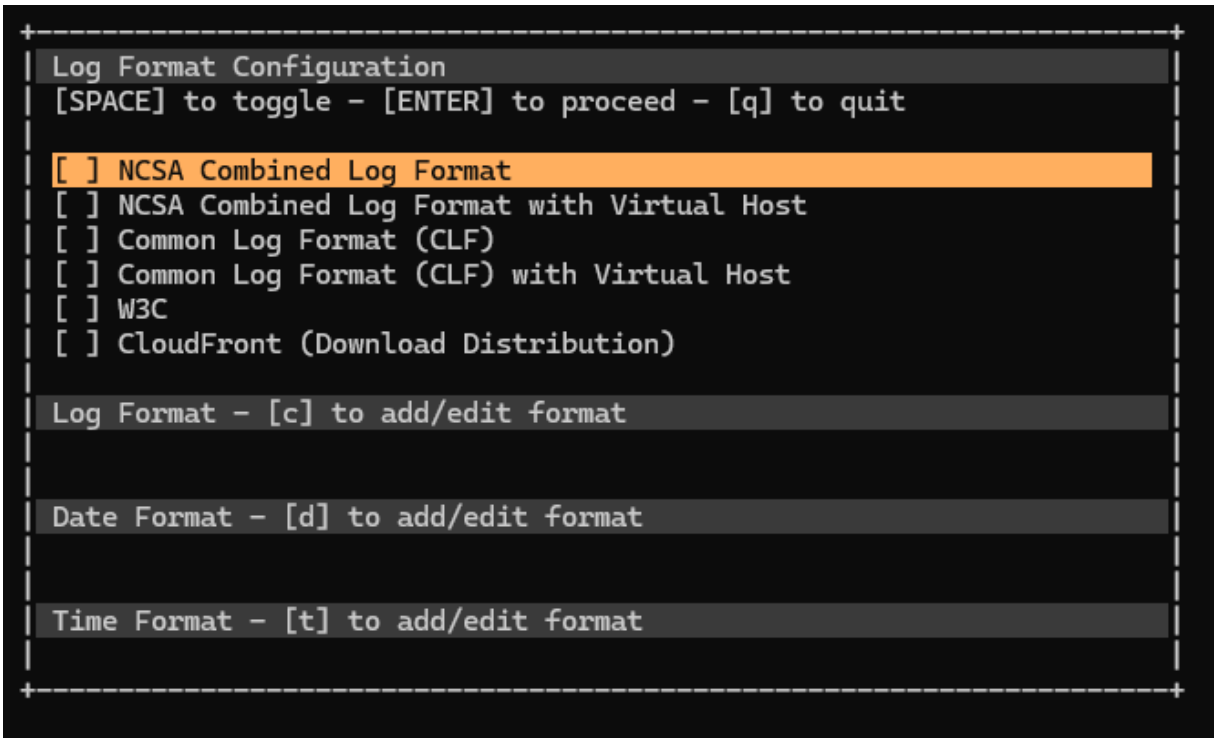
GoAccess est un analyseur de logs en temps réel qui fournit des statistiques détaillées sur le trafic web.

Installation de GoAccess

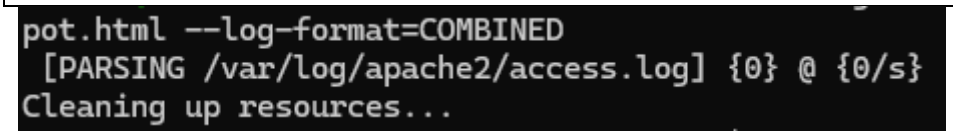
```
$ sudo apt install goaccess
```

Utilisation en ligne de commande

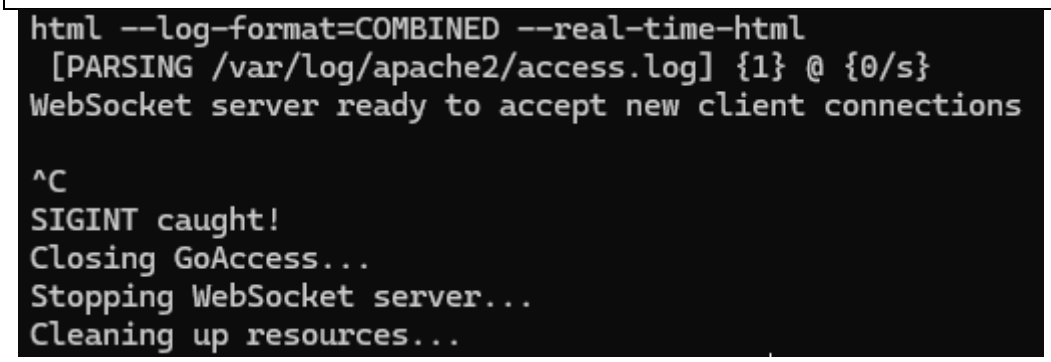
```
# Analyse interactive en temps réel
$ sudo goaccess /var/log/apache2/access.log -c
```




```
# Générer un rapport HTML
$ sudo goaccess /var/log/apache2/access.log -o /var/www/html/report.html --log-
format=COMBINED
```




```
# Analyse en temps réel avec rapport HTML auto-actualisé
$ sudo goaccess /var/log/apache2/access.log -o /var/www/html/report.html --log-
format=COMBINED --real-time-html
```



Protection du rapport

Protégez l'accès au rapport avec une authentification :

```
$ sudo nano /etc/apache2/sites-available/www.mysite.net.conf
```

Ajoutez :

```
<Directory /var/www/html/report.html>
   AuthType Basic
   AuthName "Monitoring - Accès restreint"
   AuthUserFile /etc/apache2/passwords
```

```
    Require valid-user
</Directory>
```

Configuration de la rotation des logs

Vérifiez la configuration de logrotate :

```
$ sudo nano /etc/logrotate.d/apache2
```

Configuration recommandée :

```
/var/log/apache2/*.log { daily
Missingok
rotate 14
compress
delaycompress
notifempty
create 640 root adm
sharedscripts
postrotate
/etc/init.d/apache2 reload > /dev/null
endscript
}
```

Partie 5 : Tests de sécurité et validation

Après avoir configuré toutes les mesures de sécurité, il est essentiel de les tester.

Test avec Nikto

Nikto est un scanner de vulnérabilités web :

```
$ sudo apt install nikto

# Scan basique
$ nikto -h https://localhost -ssl
```

```
elisee@elisee-VMware-Virtual-Platform:~$ nikto -h https://localhost -ssl
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject: /C=AU/ST=Some-State/O=Internet Widgits Pty Ltd
                   Ciphers: TLS_AES_256_GCM_SHA384
                   Issuer:  /C=AU/ST=Some-State/O=Internet Widgits Pty Ltd
+ Start Time:         2025-12-09 18:09:09 (GMT1)
---------------------------------------------------------------------------
+ Server: Apache/2.4.58 (Ubuntu)
+ Uncommon header 'permissions-policy' found, with contents: geolocation=(), microphone=(), camera=()
+ Uncommon header 'x-frame-options' found, with contents: SAMEORIGIN
+ Uncommon header 'x-content-type-options' found, with contents: nosniff
+ Uncommon header 'x-xss-protection' found, with contents: 1; mode=block
+ Uncommon header 'referrer-policy' found, with contents: strict-origin-when-cross-origin
+ Uncommon header 'content-security-policy' found, with contents: default-src 'self';    script-src 's
elf'; style-src 'self' 'unsafe-inline';    img-src 'self' data:; font-src 'self';    frame-ancestors '
self'; form-action 'self'
+ No CGI Directories found (use '-C all' to force check all possible dirs)
```

```
# Scan avec rapport
$ nikto -h https://localhost -ssl -o rapport_nikto.html -Format html
```

```
elisee@elisee-VMware-Virtual-Platform:~$ nikto -h https://localhost -ssl -o rapport_nikto.html -Format
 htmlml
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject: /C=AU/ST=Some-State/O=Internet Widgits Pty Ltd
                   Ciphers: TLS_AES_256_GCM_SHA384
                   Issuer:  /C=AU/ST=Some-State/O=Internet Widgits Pty Ltd
+ Start Time:         2025-12-09 18:10:26 (GMT1)
---------------------------------------------------------------------------
+ Server: Apache/2.4.58 (Ubuntu)
+ Uncommon header 'content-security-policy' found, with contents: default-src 'self';    script-src 's
elf'; style-src 'self' 'unsafe-inline';    img-src 'self' data:; font-src 'self';    frame-ancestors '
self'; form-action 'self'
+ Uncommon header 'referrer-policy' found, with contents: strict-origin-when-cross-origin
+ Uncommon header 'permissions-policy' found, with contents: geolocation=(), microphone=(), camera=()
+ Uncommon header 'x-content-type-options' found, with contents: nosniff
+ Uncommon header 'x-xss-protection' found, with contents: 1; mode=block
+ Uncommon header 'x-frame-options' found, with contents: SAMEORIGIN
+ No CGI Directories found (use '-C all' to force check all possible dirs)

^Celisee@elisee-VMware-Virtual-Platform:~$ ls
Desktop    Downloads  Pictures  rapport_nikto.html  Templates   Videos
Documents  Music      Public    snap                testssl.sh
```

Test SSL/TLS avec testssl.sh

```
$ git clone --depth 1 https://github.com/drwetter/testssl.sh.git
$ cd testssl.sh

# Test complet
$ ./testssl.sh https://localhost
```

```
elisee@elisee-VMware-Virtual-Platform:~/testssl.sh$ ./testssl.sh https://localhost

###########################################################################
  testssl.sh version 3.3dev from https://testssl.sh/dev/
  (7a0b62e 2025-12-09 12:43:05)

  This program is free software. Distribution and modification under
  GPLv2 permitted. USAGE w/o ANY WARRANTY. USE IT AT YOUR OWN RISK!

  Please file bugs @ https://testssl.sh/bugs/
###########################################################################

  Using OpenSSL 1.0.2-bad (Mar 28 2025)  [~179 ciphers]
  on elisee-VMware-Virtual-Platform:./bin/openssl.Linux.x86_64

Testing all IPv4 addresses (port 443): 127.0.0.1
---------------------------------------------------------------------------
 Start 2025-12-09 18:11:24        -->> 127.0.0.1:443 (localhost) <<--

 A record via:           /etc/hosts
 rDNS (127.0.0.1):       localhost.
 Service detected:       HTTP

 Testing protocols via sockets except NPN+ALPN

 SSLv2      not offered (OK)
 SSLv3      not offered (OK)
 TLS 1      not offered
 TLS 1.1    not offered
 TLS 1.2    offered (OK)
 TLS 1.3    offered (OK): final
 QUIC       Local problem: No OpenSSL QUIC support
 NPN/SPDY   not offered
 ALPN/HTTP2 http/1.1 (offered)

 Testing cipher categories

 NULL ciphers (no encryption)                      not offered (OK)
 Anonymous NULL Ciphers (no authentication)        not offered (OK)
 Export ciphers (w/o ADH+NULL)                     not offered (OK)
 LOW: 64 Bit + DES, RC[2,4], MD5 (w/o export)      not offered (OK)
 Triple DES Ciphers / IDEA                         not offered
 Obsoleted CBC ciphers (AES, ARIA etc.)            offered
 Strong encryption (AEAD ciphers) with no FS       offered (OK)
 Forward Secrecy strong encryption (AEAD ciphers)  offered (OK)


 Testing server's cipher preferences

Hexcode  Cipher Suite Name (OpenSSL)       KeyExch.   Encryption  Bits     Cipher Suite Name (IANA/RFC)
-----------------------------------------------------------------------------------------------------------
SSLv2
 -
SSLv3
 -
TLSv1
 -
TLSv1.1
 -
TLSv1.2
```

```
TLSv1.2 (no server order, thus listed by strength)
 xc030   ECDHE-RSA-AES256-GCM-SHA384       ECDH 521   AESGCM      256      TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
 xc028   ECDHE-RSA-AES256-SHA384           ECDH 521   AES         256      TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
 xc014   ECDHE-RSA-AES256-SHA              ECDH 521   AES         256      TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
 x9f     DHE-RSA-AES256-GCM-SHA384         DH 2048    AESGCM      256      TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
 xcca8   ECDHE-RSA-CHACHA20-POLY1305       ECDH 521   ChaCha20    256      TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_S
 xccaa   DHE-RSA-CHACHA20-POLY1305         DH 2048    ChaCha20    256      TLS_DHE_RSA_WITH_CHACHA20_POLY1305_SHA
 xc0a3   DHE-RSA-AES256-CCM8               DH 2048    AESCCM8     256      TLS_DHE_RSA_WITH_AES_256_CCM_8
 xc09f   DHE-RSA-AES256-CCM                DH 2048    AESCCM      256      TLS_DHE_RSA_WITH_AES_256_CCM
 x6b     DHE-RSA-AES256-SHA256             DH 2048    AES         256      TLS_DHE_RSA_WITH_AES_256_CBC_SHA256
 x39     DHE-RSA-AES256-SHA                DH 2048    AES         256      TLS_DHE_RSA_WITH_AES_256_CBC_SHA
 xc077   ECDHE-RSA-CAMELLIA256-SHA384      ECDH 521   Camellia    256      TLS_ECDHE_RSA_WITH_CAMELLIA_256_CBC_SH
 xc4     DHE-RSA-CAMELLIA256-SHA256        DH 2048    Camellia    256      TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA2
 x88     DHE-RSA-CAMELLIA256-SHA           DH 2048    Camellia    256      TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA
 x9d     AES256-GCM-SHA384                 RSA        AESGCM      256      TLS_RSA_WITH_AES_256_GCM_SHA384
 xc0a1   AES256-CCM8                       RSA        AESCCM8     256      TLS_RSA_WITH_AES_256_CCM_8
 xc09d   AES256-CCM                        RSA        AESCCM      256      TLS_RSA_WITH_AES_256_CCM
 x3d     AES256-SHA256                     RSA        AES         256      TLS_RSA_WITH_AES_256_CBC_SHA256
 x35     AES256-SHA                        RSA        AES         256      TLS_RSA_WITH_AES_256_CBC_SHA
 xc0     CAMELLIA256-SHA256                RSA        Camellia    256      TLS_RSA_WITH_CAMELLIA_256_CBC_SHA256
 x84     CAMELLIA256-SHA                   RSA        Camellia    256      TLS_RSA_WITH_CAMELLIA_256_CBC_SHA
 xc051   ARIA256-GCM-SHA384               RSA        ARIAGCM     256      TLS_RSA_WITH_ARIA_256_GCM_SHA384
 xc053   DHE-RSA-ARIA256-GCM-SHA384        DH 2048    ARIAGCM     256      TLS_DHE_RSA_WITH_ARIA_256_GCM_SHA384
 xc061   ECDHE-ARIA256-GCM-SHA384          ECDH 521   ARIAGCM     256      TLS_ECDHE_RSA_WITH_ARIA_256_GCM_SHA384
 xc02f   ECDHE-RSA-AES128-GCM-SHA256       ECDH 521   AESGCM      128      TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
 xc027   ECDHE-RSA-AES128-SHA256           ECDH 521   AES         128      TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256
 xc013   ECDHE-RSA-AES128-SHA              ECDH 521   AES         128      TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
 x9e     DHE-RSA-AES128-GCM-SHA256         DH 2048    AESGCM      128      TLS_DHE_RSA_WITH_AES_128_GCM_SHA256
 xc0a2   DHE-RSA-AES128-CCM8               DH 2048    AESCCM8     128      TLS_DHE_RSA_WITH_AES_128_CCM_8
 xc09e   DHE-RSA-AES128-CCM                DH 2048    AESCCM      128      TLS_DHE_RSA_WITH_AES_128_CCM
 xc0a0   AES128-CCM8                       RSA        AESCCM8     128      TLS_RSA_WITH_AES_128_CCM_8
 xc09c   AES128-CCM                        RSA        AESCCM      128      TLS_RSA_WITH_AES_128_CCM
 x67     DHE-RSA-AES128-SHA256             DH 2048    AES         128      TLS_DHE_RSA_WITH_AES_128_CBC_SHA256
 x33     DHE-RSA-AES128-SHA                DH 2048    AES         128      TLS_DHE_RSA_WITH_AES_128_CBC_SHA
 xc076   ECDHE-RSA-CAMELLIA128-SHA256      ECDH 521   Camellia    128      TLS_ECDHE_RSA_WITH_CAMELLIA_128_CBC_SH
 xbe     DHE-RSA-CAMELLIA128-SHA256        DH 2048    Camellia    128      TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA2
 x45     DHE-RSA-CAMELLIA128-SHA           DH 2048    Camellia    128      TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA
 x9c     AES128-GCM-SHA256                 RSA        AESGCM      128      TLS_RSA_WITH_AES_128_GCM_SHA256
 x3c     AES128-SHA256                     RSA        AES         128      TLS_RSA_WITH_AES_128_CBC_SHA256
 x2f     AES128-SHA                        RSA        AES         128      TLS_RSA_WITH_AES_128_CBC_SHA
 xba     CAMELLIA128-SHA256                RSA        Camellia    128      TLS_RSA_WITH_CAMELLIA_128_CBC_SHA256
 x41     CAMELLIA128-SHA                   RSA        Camellia    128      TLS_RSA_WITH_CAMELLIA_128_CBC_SHA
 xc050   ARIA128-GCM-SHA256               RSA        ARIAGCM     128      TLS_RSA_WITH_ARIA_128_GCM_SHA256
 xc052   DHE-RSA-ARIA128-GCM-SHA256        DH 2048    ARIAGCM     128      TLS_DHE_RSA_WITH_ARIA_128_GCM_SHA256
 xc060   ECDHE-ARIA128-GCM-SHA256          ECDH 521   ARIAGCM     128      TLS_ECDHE_RSA_WITH_ARIA_128_GCM_SHA256
TLSv1.3 (no server order, thus listed by strength)
 x1302   TLS_AES_256_GCM_SHA384            ECDH 253   AESGCM      256      TLS_AES_256_GCM_SHA384
 x1303   TLS_CHACHA20_POLY1305_SHA256      ECDH 253   ChaCha20    256      TLS_CHACHA20_POLY1305_SHA256
 x1301   TLS_AES_128_GCM_SHA256            ECDH 253   AESGCM      128      TLS_AES_128_GCM_SHA256

 Has server cipher order?     no (NOT ok)
 (limited sense as client will pick)

 Testing robust forward secrecy (FS) -- omitting Null Authentication/Encryption, 3DES, RC4

 FS is offered (OK)           TLS_AES_256_GCM_SHA384 TLS_CHACHA20_POLY1305_SHA256
                              ECDHE-RSA-AES256-GCM-SHA384 ECDHE-RSA-AES256-SHA384
                              ECDHE-RSA-AES256-SHA DHE-RSA-AES256-GCM-SHA384
                              ECDHE-RSA-CHACHA20-POLY1305 DHE-RSA-CHACHA20-POLY1305
                              DHE-RSA-AES256-CCM8 DHE-RSA-AES256-CCM DHE-RSA-AES256-SHA256
                              DHE-RSA-AES256-SHA ECDHE-RSA-CAMELLIA256-SHA384
                              DHE-RSA-CAMELLIA256-SHA256 DHE-RSA-CAMELLIA256-SHA
                              DHE-RSA-ARIA256-GCM-SHA384 ECDHE-ARIA256-GCM-SHA384
                              TLS_AES_128_GCM_SHA256 ECDHE-RSA-AES128-GCM-SHA256
                              ECDHE-RSA-AES128-SHA256 ECDHE-RSA-AES128-SHA DHE-RSA-AES128-GCM-SHA256
                              DHE-RSA-AES128-CCM8 DHE-RSA-AES128-CCM DHE-RSA-AES128-SHA256
                              DHE-RSA-AES128-SHA ECDHE-RSA-CAMELLIA128-SHA256
                              DHE-RSA-CAMELLIA128-SHA256 DHE-RSA-CAMELLIA128-SHA
```

```
# Test avec rapport HTML
$ ./testssl.sh --html https://localhost
```

```
elisee@elisee-VMware-Virtual-Platform:~/testssl.sh$ ./testssl.sh --html https://localhost

###########################################################################
  testssl.sh version 3.3dev from https://testssl.sh/dev/
  (7a0b62e 2025-12-09 12:43:05)

  This program is free software. Distribution and modification under
  GPLv2 permitted. USAGE w/o ANY WARRANTY. USE IT AT YOUR OWN RISK!

  Please file bugs @ https://testssl.sh/bugs/
###########################################################################

  Using OpenSSL 1.0.2-bad (Mar 28 2025)  [~179 ciphers]
  on elisee-VMware-Virtual-Platform:./bin/openssl.Linux.x86_64

Testing all IPv4 addresses (port 443): 127.0.0.1
--------------------------------------------------------------------------------------------------------------------------------------------------------
 Start 2025-12-09 18:12:48        -->> 127.0.0.1:443 (localhost) <<--

 A record via:           /etc/hosts
 rDNS (127.0.0.1):       localhost.
 Service detected:       HTTP

 Testing protocols via sockets except NPN+ALPN

 SSLv2      not offered (OK)
 SSLv3      not offered (OK)
 TLS 1      not offered
 TLS 1.1    not offered
 TLS 1.2    offered (OK)
 TLS 1.3    offered (OK): final
 QUIC       Local problem: No OpenSSL QUIC support
 NPN/SPDY   ./testssl.sh --html https://localhostnot offered
 ALPN/HTTP2 http/1.1 (offered)

 Testing cipher categories

 NULL ciphers (no encryption)                      not offered (OK)
 Anonymous NULL Ciphers (no authentication)        not offered (OK)
 Export ciphers (w/o ADH+NULL)                     not offered (OK)
 LOW: 64 Bit + DES, RC[2,4], MD5 (w/o export)      not offered (OK)
 Triple DES Ciphers / IDEA                         not offered
 Obsoleted CBC ciphers (AES, ARIA etc.)            offered
 Strong encryption (AEAD ciphers) with no FS       offered (OK)
 Forward Secrecy strong encryption (AEAD ciphers)  offered (OK)


 Testing server's cipher preferences

Hexcode  Cipher Suite Name (OpenSSL)       KeyExch.   Encryption  Bits     Cipher Suite Name (IANA/RFC)
------------------------------------------------------------------------------------------------------------------------------------------------------
SSLv2
 -
SSLv3
 -
TLSv1
 -
TLSv1.1
 -
```

Vérification des en-têtes avec curl

```
# Afficher tous les en-têtes
$ curl -I -k https://localhost
```

```
elisee@elisee-VMware-Virtual-Platform:~$ curl -I -k https://localhost
HTTP/1.1 200 OK
Date: Tue, 09 Dec 2025 17:13:51 GMT
Server: Apache/2.4.58 (Ubuntu)
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self';    script-src 'self'; style-src 'self' 'unsafe-inline';    img-src 'self' data:; font-src
 'self';    frame-ancestors 'self'; form-action 'self'
Permissions-Policy: geolocation=(), microphone=(), camera=()
Last-Modified: Tue, 09 Dec 2025 14:54:02 GMT
ETag: "29af-64586151ca664"
Accept-Ranges: bytes
Content-Length: 10671
Vary: Accept-Encoding
Content-Type: text/html
```

```
# Vérifier un en-tête spécifique
$ curl -I -k https://localhost | grep -i "content-security-policy"
```

```
elisee@elisee-VMware-Virtual-Platform:~$ curl -I -k https://localhost | grep -i "content-security-policy"
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
  0 10671    0     0    0     0      0      0 --:--:-- --:--:-- --:--:--     0
Content-Security-Policy: default-src 'self';    script-src 'self'; style-src 'self' 'unsafe-inline';    img-src 'self' data:; font-src
 'self';    frame-ancestors 'self'; form-action 'self'
```

```
# Test complet avec verbose
$ curl -v -k https://localhost 2>&1 | grep -E "^(<|>)"
```

```
elisee@elisee-VMware-Virtual-Platform:~$ curl -v -k https://localhost 2>&1 | grep -E "^(<|>)"
> GET / HTTP/1.1
> Host: localhost
> User-Agent: curl/8.5.0
> Accept: */*
>
< HTTP/1.1 200 OK
< Date: Tue, 09 Dec 2025 17:14:26 GMT
< Server: Apache/2.4.58 (Ubuntu)
< X-Frame-Options: SAMEORIGIN
< X-XSS-Protection: 1; mode=block
< X-Content-Type-Options: nosniff
< Referrer-Policy: strict-origin-when-cross-origin
< Content-Security-Policy: default-src 'self';    script-src 'self'; style-src 'self' 'unsafe-inline';    img-src 'self' data:; font-s
rc 'self';    frame-ancestors 'self'; form-action 'self'
< Permissions-Policy: geolocation=(), microphone=(), camera=()
< Last-Modified: Tue, 09 Dec 2025 14:54:02 GMT
< ETag: "29af-64586151ca664"
< Accept-Ranges: bytes
< Content-Length: 10671
< Vary: Accept-Encoding
< Content-Type: text/html
<
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
</html>
```

Test de ModSecurity

```
# Test injection SQL
$ curl -k "https://localhost/?id=1' OR '1'='1"

# Si ça ne marche pas, essayez avec :
curl -kG 'https://localhost/' --data-urlencode "id=1' OR '1'='1"
```

```
elisee@elisee-VMware-Virtual-Platform:~$ curl -kG 'https://localhost/' --data-urlencode "id=1' OR '1'=
'1"
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at localhost Port 443</address>
</body></html>
```

```
# Test XSS
$ curl -k "https://localhost/?q=<script>alert(1)</script>"
```

```
elisee@elisee-VMware-Virtual-Platform:~$ curl -k "https://localhost/?q=<script>alert(1)</script>"
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at localhost Port 443</address>
</body></html>
```

```
# Vérifier les blocages dans les logs
$ sudo tail -20 /var/log/apache2/modsec_audit.log
```



Checklist de validation

Vérifiez les points suivants :

1. ModSecurity bloque les requêtes malveillantes (vérifier les logs)
2. Fail2Ban est actif et les jails sont fonctionnels
3. Tous les en-têtes de sécurité sont présents (curl -I)
4. HTTPS fonctionne correctement avec le certificat
5. GoAccess génère bien les rapports de monitoring
6. Nikto ne détecte pas de vulnérabilités critiques

Pour aller encore plus loin

Voici des pistes pour approfondir la sécurisation de votre serveur :

Certificats Let's Encrypt

Remplacez le certificat auto-signé par un certificat Let's Encrypt gratuit et reconnu :

```
$ sudo apt install certbot python3-certbot-apache
$ sudo certbot --apache -d votredomaine.com
```

Let's Encrypt nécessite un domaine public valide (pas localhost/IP privée). Comme on est en lab local, on est resté en auto-signé avec -k dans curl

Configuration TLS avancée

Désactivez les protocoles et ciphers obsolètes :

```
# Dans /etc/apache2/mods-available/ssl.conf
SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1
SSLCipherSuite ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256
SSLHonorCipherOrder on
SSLCompression off
SSLSessionTickets off
```

Autres outils à explorer

Outil	Usage
OSSEC	HIDS - Détection d'intrusion sur l'hôte
ClamAV	Antivirus open source pour scanner les uploads
Lynis	Audit de sécurité et hardening du système
OWASP ZAP	Scanner de vulnérabilités web automatisé
Prometheus + Grafana	Monitoring avancé avec tableaux de bord